

Ensemble

Infrastructure reference — ensemble.it.com

Generated 1 September 2026 from the repository at commit cea8c82.

Request path

One DigitalOcean droplet runs everything. There is no separate database server, no container orchestration and no CDN — Caddy terminates TLS and reverse-proxies a single Next.js process, which reads and writes a SQLite file on the same disk.

```
Visitor
|
v
DNS ensemble.it.com / www / sites.* -> reserved IP (A records)
    a creator's own domain -> reserved IP (A) or sites.* (CNAME)
|
v
Caddy :80 / :443 TLS, managed certs for platform hosts,
    on-demand certs for creator domains
    | gated by -> GET /api/domains/check (is this a known customer domain?)
    v
Next.js :3000 systemd unit 'ensemble', runs as user 'ensemble'
    |
    |-- src/proxy.ts Host in PLATFORM_HOSTS ? serve platform
    | otherwise rewrite to /domain/[host]
    v
SQLite /srv/ensemble/data/app.db (WAL mode, in-process via better-sqlite3)

MediaMTX :1935 (optional) RTMP in from OBS -> ffmpeg fan-out to platforms
```

Because the app is one process against a local file, everything mutable lives in one directory. That is the whole backup surface, and also the whole scaling ceiling.

Hostname routing

PLATFORM_HOSTS is the pivot of the entire routing model. Any Host header not in that list is treated as a creator's connected domain and rewritten to `/domain/[host]`, which resolves it against the `custom_domains` table. If the marketing site ever 404s, this is the first thing to check.

Hostname	Treated as	Certificate
ensemble.it.com	Platform — marketing, dashboard, /s/ pages	Managed
www.ensemble.it.com	Platform. Not canonicalised to the apex — visitors stay on www	Managed
sites.ensemble.it.com	Platform, and the CNAME target creators point at. A bare visit redirects to APP_URL	Managed
localhost	Platform, for local development	n/a
anything else	A creator's custom domain, rewritten to /domain/[host]	On demand

www is a live footgun. It is a platform host and is never redirected to the apex, so a creator can browse the entire dashboard on www. Anything that derives an absolute URL from the request Host therefore produces a www URL. That is exactly what broke Instagram OAuth (fixed in 215dfda by deriving redirect_uri from APP_URL instead). Any future feature that builds a URL from the Host header inherits the same bug.

Custom-domain certificate gate

Caddy asks the app before minting any certificate. Without that gate, anyone could point DNS at the reserved IP and burn the Let's Encrypt rate limit. The endpoint answers 200 or 404, which would also let anyone enumerate which domains are customers — so the Caddyfile returns 403 for it at the edge, via a snippet imported into every site block. **A new site block without that import re-exposes it.**

Runtime and services

Unit	What it is	Notes
ensemble.service	The Next.js app, <code>npm run start</code> on <code>:3000</code>	User ensemble, WorkingDirectory /srv/ensemble, Restart=always. Reads .env from the working directory at runtime , so an env change needs a restart but not a rebuild.
caddy	TLS termination and reverse proxy	Config at /etc/caddy/Caddyfile. Reload, don't restart.
mediamtx	RTMP relay for simulcasting (optional)	Only needed for the Enterprise live feature. Without it everything else runs and the dashboard shows a 'nearly here' state.

Stack

Node 22 LTS on the droplet (Node 20 locally). Next.js 16.3 with Turbopack, React, TypeScript, Tailwind 4. Runtime dependencies are deliberately few: better-sqlite3, stripe, node-html-parser, simple-icons. No ORM — SQL is hand-written in `src/lib/db.ts`. better-sqlite3 compiles natively, which is why build-essential and python3 are installed.

Data

A single SQLite file at `/srv/ensemble/data/app.db`, opened in WAL mode with `busy_timeout=5000` and `foreign_keys=ON`. The path is resolved as `process.cwd() + /data`, so it follows the working directory — and tables are created on demand, which means launching from the wrong directory silently produces a fresh empty database rather than an error.

20 tables

```
users sessions auth_tokens user_prefs
sites sections site_content custom_domains
leads newsletter_posts chat_messages support_tickets
social_accounts social_posts social_post_targets social_stats
follower_counts page_views connections quote_requests
```

`auth_tokens` is new: one purpose-keyed table behind password reset, recovery-address confirmation and login recovery. Design settings are **not** columns — they live in a JSON config blob on sites, so new appearance settings need no migration.

WAL files are part of the database. On the machine this was generated from, `app.db` was 4 KB while `app.db-wal` held 1 MB of uncheckpointed data. Copying `app.db` alone captures an almost empty database. The nightly cron uses `sqlite3 .backup`, which handles this correctly — but any manual copy, `rsync` or snapshot script must take all three files together.

Backups

Everything mutable is `/srv/ensemble/data/` — the database plus uploads. A cron job at 04:00 writes a day-of-week rotated snapshot, giving seven days of history. DigitalOcean droplet snapshots cover the rest of the disk.

```
0 4 * * * sqlite3 /srv/ensemble/data/app.db \
    ".backup /srv/ensemble/data/backup-$(date +%u).db"
```

External services

Every one of these is optional and fails soft. The app inspects its own environment and switches the feature on only when credentials appear; until then the relevant tab says so rather than erroring.

Service	Enables	Credentials from	Off when unset
Stripe	Subscription billing	dashboard.stripe.com	Preview mode — plan changes instant and free, every page may publish unbilled
Resend	Password reset, account recovery, creator newsletters	resend.com	Pages state plainly that mail is off; lists still collect subscribers
Meta	Threads, Instagram, Facebook publishing	developers.facebook.com — one app, three products	Those platforms are not offered
Pinterest	Pinterest publishing	developers.pinterest.com/apps	Not offered
Reddit	Reddit publishing	reddit.com/prefs/apps	Not offered
Intuit	QuickBooks on the Analytics tab	developer.intuit.com	One-click connect stays off

OAuth redirect URIs to register

These must match the apex exactly. They are built from APP_URL, so if APP_URL is wrong or unset on the droplet, every social connection fails with an invalid-redirect error regardless of what is registered.

```
https://ensemble.it.com/api/oauth/instagram/callback  
https://ensemble.it.com/api/oauth/facebook/callback  
https://ensemble.it.com/api/oauth/threads/callback  
https://ensemble.it.com/api/oauth/pinterest/callback  
https://ensemble.it.com/api/oauth/reddit/callback
```

Stripe webhook

Endpoint `https://ensemble.it.com/api/stripe/webhook`, subscribed to exactly the six events the code handles:

```
checkout.session.completed customer.subscription.updated  
checkout.session.async_payment_succeeded customer.subscription.deleted  
checkout.session.async_payment_failed invoice.payment_failed
```

Environment

Single file at `/srv/ensemble/.env`. Loaded at runtime, so changes take effect on `systemctl restart ensemble` with no rebuild.

Variable	Purpose	Source
PLATFORM_HOSTS	Hosts served as the platform. Everything else is a customer domain	You
APP_URL	Canonical absolute URL. Builds OAuth <code>redirect_uri</code> , Stripe return links and recovery links	You
DOMAIN_A_RECORD	Droplet's reserved IP, shown in DNS instructions	DigitalOcean
DOMAIN_CNAME_TARGET	<code>sites.ensemble.it.com</code>	You
ADMIN_EMAIL / ADMIN_PASSWORD	Seeds the admin on first run only ; inert afterwards	You
WIP_MODE	1 holds the launch: signed-out visitors bounce to the landing page	You
STRIPE_SECRET_KEY	Live billing	Stripe
STRIPE_WEBHOOK_SECRET	Verifies webhook signatures	Stripe
RESEND_API_KEY	Switches on all outbound mail	Resend
AUTH_MAIL_FROM	Platform mail sender. Default <code>noreply@ensemble.it.com</code>	You
MAIL_FROM	Creator newsletter sender, under the creator's display name	You
THREADS / INSTAGRAM / FACEBOOK / PINTEREST / REDDIT _APP_ID and _APP_SECRET	Social publishing	Each platform
INTUIT_CLIENT_ID / _SECRET	QuickBooks	Intuit
LIVE_INGEST_URL / LIVE_HOOK_SECRET	Simulcast relay. Secret is shared with <code>mediamtx.service</code>	You

Two env caveats worth writing on the wall. (1) `ADMIN_PASSWORD` applies only when the database is first created — setting it later does nothing, because seeding returns early once the account exists. The live credential is a script hash and is not recoverable; rotate with `scripts/set-admin-password.mjs`. (2) `INTUIT_CLIENT_ID` and `INTUIT_CLIENT_SECRET` are read by the Analytics page but are absent from `.env.example`, so QuickBooks stays off with nothing naming the variables.

Ports and firewall

Port	Exposed	Why
22	Yes	SSH
80 / 443	Yes	Caddy. HTTP is needed for ACME challenges
1935	Only with the relay	RTMP ingest from creators' OBS
3000	No	Next.js, localhost only

That :3000 is unreachable from outside is load-bearing beyond the obvious. Rate limiting trusts the **last** X-Forwarded-For hop because Caddy is the only thing that can reach the app; exposing :3000 directly would make that header spoofable and every rate limit bypassable.

Deploying an update

Build as the ensemble user, never as root — building as root leaves root-owned `.next/` and `node_modules/` that the service cannot write to.

```
sudo -iu ensemble bash -lc 'cd /srv/ensemble && git pull && npm ci && npm run build'
systemctl restart ensemble
```

Smoke test

```
curl -I https://ensemble.it.com # 200, valid cert
curl -s http://localhost:3000/api/domains/check?domain=x.com # 404, unknown domain
```

Known rough edges

- **2 GB RAM minimum.** `next build` OOMs on 1 GB without swap.
- **Single point of failure by design.** App, database and TLS on one droplet; a rebuild loses everything outside `data/` and the reserved IP.
- **Relay bandwidth.** One stream to three platforms is roughly 8 GB/hour of egress. Check `vnstat` monthly before inviting more streamers.
- **DEPLOY.md is stale in one place.** Its closing note says the admin password must be changed by editing the user row manually; `scripts/set-admin-password.mjs` now does it properly.
- **WIP_MODE is currently on in production**, which is why `/signup` redirects to the landing page. Recovery routes are allowlisted through it; the signup funnel stays shut until it is turned off.